

MANUAL OPERATIVO

DataLegal

Operación y soporte

Runbooks, continuidad, incidencias y mantenimiento del servicio

Versión: 1.0

Fecha: 14 de agosto de 2026

Responsable: Equipo DataLegal

Entorno: Producción AWS y entorno local de soporte

Clasificación: Uso interno; no contiene secretos

Control del documento

Campo	Valor
Código	DL-OPS-001
Versión	1.0
Estado	Listo para revisión y aprobación
Propietario	Responsable de operaciones de DataLegal
Aprobación	<NOMBRE_APROBADOR> · <FECHA_APROBACIÓN>
Próxima revisión	Trimestral o después de un cambio de arquitectura
Fuentes	Código, pruebas, Dockerfile y despliegue AWS del repositorio DataLegal

Regla de seguridad: Este manual utiliza marcadores entre ángulos para identificadores, correos, rutas externas y datos sensibles. Sustituirlos únicamente en una copia controlada; nunca registrar contraseñas, tokens, llaves MFA ni cadenas de conexión en tickets o capturas.

Lectura rápida

Necesidad	Ir a
Confirmar si el servicio está disponible	Sección 5 · Health checks
Revisar contenedores o logs	Sección 6 · Monitoreo y registros
Atender acceso, bloqueo o baja	Sección 7 · Usuarios
Clasificar y responder una falla	Sección 8 · Incidencias
Publicar una versión o volver atrás	Secciones 10 y 11
Ejecutar continuidad o recuperación	Sección 13
Completar controles periódicos	Sección 15 · Checklists

Historial de versiones

Versión	Fecha	Cambio	Autor
1.0	14-ago-2026	Emisión inicial basada en el repositorio y despliegue AWS	Equipo DataLegal

1. Propósito, alcance y criterios

Este manual establece cómo mantener DataLegal disponible, seguro, recuperable y trazable. Está dirigido a quienes atienden el servicio después del despliegue: operación, soporte, administración funcional, desarrollo y seguridad. Sus procedimientos se apoyan en el comportamiento verificable del código y separan expresamente las capacidades actuales de las recomendaciones de mejora.

1.1 Alcance incluido

- Operación diaria del frontend, API FastAPI y PostgreSQL desplegados en AWS.
- Comprobaciones de salud desde el punto de vista del usuario y desde la instancia.
- Lectura de logs, diagnóstico inicial, clasificación de severidad y escalamiento.
- Altas, bajas, cambios de rol, bloqueo y recuperación administrativa de usuarios.
- Mantenimiento preventivo, despliegue controlado, rollback y continuidad.
- Checklists y plantillas de evidencia para que cada intervención sea auditable.

1.2 Fuera de alcance

- Administración legal o interpretación de la LOPDP; corresponde al DPO o asesoría jurídica.
- Pentesting, análisis forense formal y gestión contractual con proveedores.
- Cambios directos de datos funcionales sin ticket, aprobación y respaldo previo.
- Una arquitectura de alta disponibilidad: el despliegue actual usa una sola instancia EC2.

Criterio operativo: Si un procedimiento exige permisos o herramientas no disponibles, detener la intervención, preservar evidencia y escalar. No improvisar cambios en producción.

1.3 Convenciones

Etiqueta	Significado
Verificado	Derivado directamente del código o artefactos del repositorio.
Objetivo interno	Meta operativa propuesta; requiere aprobación del responsable.
Recomendación	Control aconsejado que no está automatizado por el despliegue actual.
<MARCADOR>	Valor que debe resolver un operador autorizado fuera de este manual.

2. Roles y responsabilidades

La separación de funciones evita que una misma persona solicite, ejecute y apruebe cambios sensibles. En equipos pequeños una persona puede cubrir más de un rol, pero el ticket debe dejar constancia de quién solicitó, ejecutó y validó.

Rol operativo	Responsabilidades principales	No debe
Mesa de ayuda (L1)	Recibir, reproducir, clasificar, comunicar y resolver casos de uso conocidos.	Acceder a la base o modificar infraestructura.
Operaciones (L2)	Health checks, logs, contenedores, respaldos, despliegues y recuperación.	Cambiar datos funcionales sin autorización.
Desarrollo (L3)	Analizar defectos, preparar correcciones, pruebas y notas de versión.	Publicar directo sin control de cambio.
Administrador funcional	Usuarios, roles, tenant, configuración y validación de negocio.	Compartir credenciales o elevar privilegios sin aprobación.
DPO / Seguridad	Evaluar incidentes de datos, evidencia, notificación y riesgo.	Eliminar evidencia o cerrar incidentes técnicos sin confirmación.
Aprobador de cambio	Aceptar ventana, riesgo, rollback y resultado.	Aprobar su propia ejecución cuando exista alternativa.

2.1 Matriz RACI mínima

Actividad	L1	L2	L3	Admin	DPO/Seg.
Monitoreo diario	R	A	C	I	I
Alta/baja de usuario	I	C	I	R/A	C
Desbloqueo excepcional	I	R	C	A	I
Incidente SEV-1	R	R	R	I	A/C
Despliegue	I	R	C	I	C
Restauración	I	R	C	A	C

R = responsable de ejecutar; A = responsable de aprobar; C = consultado; I = informado.

3. Servicio y arquitectura operativa

El despliegue AWS del MVP usa CloudFront como ingreso público y una instancia EC2 con tres contenedores Docker en una red privada. El frontend y la API comparten origen: Nginx sirve el build de Vite y reenvía /api al backend. PostgreSQL no se publica a Internet.

Topología AWS implementada

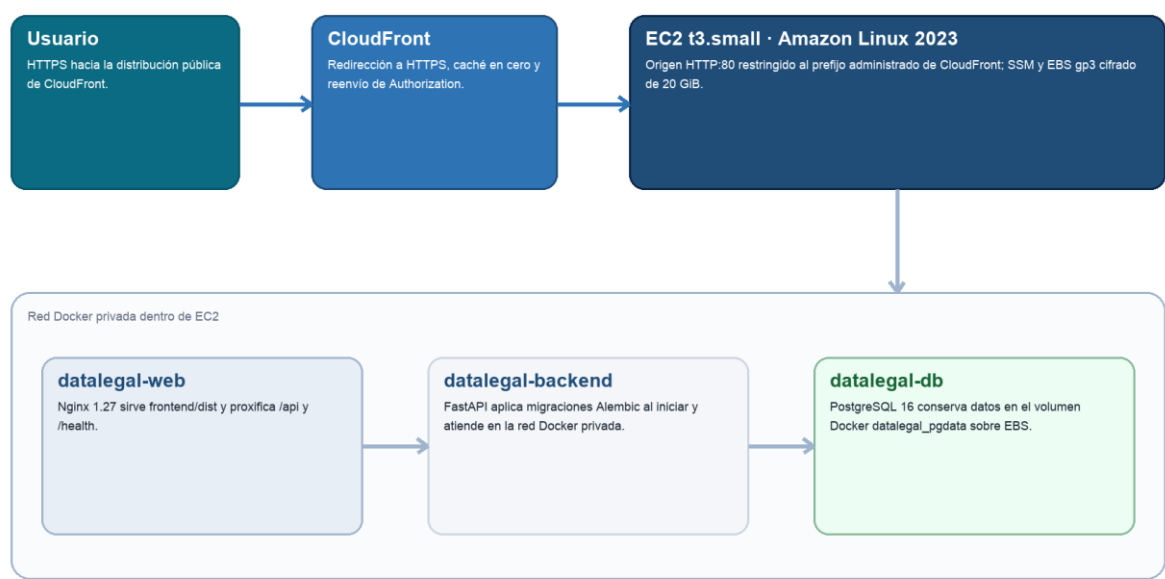


Figura 1. Arquitectura AWS documentada en el repositorio.

Componente	Función	Indicador primario
CloudFront	HTTPS, compresión y reenvío al origen; caché desactivada.	Estado Enabled; errores 4xx/5xx.
EC2	Amazon Linux 2023; Docker; volumen raíz EBS cifrado.	Status checks, CPU, disco y memoria.
datalegal-web	Nginx 1.27; estáticos y proxy /api.	Página de login y acceso /health.
datalegal-backend	FastAPI; migraciones Alembic al arranque.	GET /health y logs de Uvicorn.
datalegal-db	PostgreSQL 16 en volumen Docker persistente.	pg_isready, conexiones y espacio.
SSM	Acceso administrativo sin exponer SSH.	Instancia administrada y sesión autorizada.

Punto único de falla: La EC2 actual concentra web, API y base. Una falla de instancia afecta todo el servicio; por eso los respaldos externos, la prueba de restauración y el monitoreo de capacidad son controles críticos.

3.1 Límites de confianza

- El grupo de seguridad acepta el puerto 80 únicamente desde la lista administrada de orígenes CloudFront.
- Los puertos de FastAPI y PostgreSQL no se publican; se accede desde la red Docker o mediante SSM autorizado.
- Los secretos productivos residen en `/opt/datalegal/backend.env` con permisos restringidos y no deben copiarse al repositorio.
- La documentación interactiva de FastAPI debe responder 404 en producción.

Fuente: docs/deployment-aws.md, deploy/aws/deploy-datalegal.sh, backend/Dockerfile y backend/app/main.py.

4. Operación diaria

4.1 Inicio de jornada

- Revisar el canal de incidencias y los tickets abiertos desde la jornada anterior.
- Comprobar la URL pública, el formulario de acceso y la respuesta de /health.
- Validar que los tres contenedores estén Up y que PostgreSQL acepte conexiones.
- Revisar errores recientes del backend, reinicios de contenedores, disco y memoria.
- Confirmar que el último respaldo externo está dentro del RPO y que tiene checksum registrado.
- Registrar hora, operador, resultados y excepciones en la bitácora diaria.

4.2 Durante la jornada

- Atender primero seguridad, indisponibilidad y vencimientos regulatorios; luego degradaciones y solicitudes normales.
- Mantener una sola fuente de verdad por caso: ticket, severidad, dueño, hora de próxima actualización y evidencia.
- Evitar reinicios como primera respuesta. Reunir health, logs, estado de recursos y cambio reciente antes de actuar.
- No ejecutar migraciones, limpieza, restore o cambios de usuario privilegiado fuera de un ticket aprobado.

4.3 Cierre de jornada

- No quedan alertas críticas sin propietario.
- Los tickets activos incluyen diagnóstico, acciones, próximo paso y hora de actualización.
- Los cambios ejecutados tienen evidencia de validación o plan de reversión activo.
- Los respaldos o jobs fallidos fueron escalados, no solo reintentados.
- El relevo recibió los SEV-1/SEV-2 y vencimientos próximos.

4.4 Parada y arranque controlados

Ventana requerida: El despliegue es de instancia única. Una parada o recreación de backend/web puede ser visible para usuarios; anunciar ventana y congelar operaciones críticas.

```
# Desde una sesión SSM autorizada
cd /opt/datalegal/repo
docker ps --format 'table {{.Names}}\t{{.Status}}\t{{.Image}}'
docker stop datalegal-web datalegal-backend
docker stop datalegal-db

# Arranque: primero datos, luego API y finalmente web
docker start datalegal-db
docker exec datalegal-db pg_isready -U datalegal -d datalegal
docker start datalegal-backend
docker start datalegal-web
```

- Esperar la disponibilidad de cada capa antes de iniciar la siguiente.
- Después del arranque, ejecutar los cuatro checks de aceptación de la sección 5.4.
- Si un contenedor vuelve a detenerse, no repetir reinicios: capturar logs y escalar como incidencia.

5. Health checks y criterios de servicio

5.1 Nivel 0 — experiencia del usuario

- La URL pública carga por HTTPS sin advertencias de certificado.
- Se muestra la pantalla de inicio de sesión y sus recursos visuales.
- Una cuenta de prueba autorizada puede autenticar y abrir el dashboard.
- Una consulta de solo lectura devuelve datos del tenant correcto.
- Cerrar sesión elimina el acceso a rutas protegidas.

Cuenta de prueba: Usar una cuenta operativa dedicada, con privilegio mínimo y credencial guardada en el gestor aprobado. No usar cuentas personales ni anotar la contraseña en la bitácora.

5.2 Nivel 1 — ingreso público

```
export DATALEGAL_URL='https://<CLOUDFRONT_DOMAIN>'
curl --fail --silent --show-error --max-time 15 "$DATALEGAL_URL/health"
curl --silent --output /dev/null --write-out '%{http_code}\n' \
"$DATALEGAL_URL/api/docs"
```

Prueba	Esperado	Falla indica
GET /	200 y login	CloudFront, origen, Nginx o artefactos frontend.
GET /health	200; status=ok; environment=production	Proxy, backend, configuración o contenedor.
GET /api/docs	404	Documentación expuesta o entorno mal configurado.
Login válido	200 o reto MFA	API, base, usuario, bloqueo, MFA o rate limit.

5.3 Nivel 2 — instancia y contenedores

```
docker ps --format 'table {{.Names}}\t{{.Status}}\t{{.Image}}'
docker inspect -f '{{.Name}} restarts={{.RestartCount}}' \
  datalegal-web datalegal-backend datalegal-db
docker exec datalegal-db pg_isready -U datalegal -d datalegal
docker exec datalegal-backend python -c \
  "import urllib.request; print(urllib.request.urlopen(\"http://127.0.0.1:8000/health\").read())"
df -h /var/lib/docker
docker stats --no-stream
```

Señal	Verde	Amarillo	Rojo
Contenedor	Up estable	Reinicio aislado explicado	Exited o bucle de reinicio
Disco	<70 %	70–84 %	≥85 % o crecimiento rápido
Memoria	Sin presión	Uso sostenido >75 %	OOM o swap severo

Señal	Verde	Amarillo	Rojo
CPU	Base normal	>70 % por 15 min	>90 % sostenido
/health	200 <2 s	Lento/intermitente	No 200 o timeout

Umbral de capacidad: objetivos internos propuestos; ajustar con una línea base real de CloudWatch.

5.4 Criterio de aceptación después de intervención

- CloudFront responde 200 para la aplicación y fuerza HTTPS.
- /health responde 200 con environment=production.
- /api/docs responde 404.
- Login, dashboard y una lectura autenticada funcionan con cuenta de prueba.
- No aparecen errores nuevos en los últimos cinco minutos de logs.
- Los tres contenedores permanecen Up sin incrementar RestartCount.

6. Monitoreo, alertas y registros

6.1 Fuentes disponibles

Fuente	Qué aporta	Acceso recomendado
CloudFront	Solicitudes, errores 4xx/5xx, latencia al origen.	Métricas AWS; habilitar logs si se aprueba.
EC2 / EBS	Status checks, CPU, red y estado del volumen.	CloudWatch y consola AWS.
Docker	Estado, reinicios, consumo y logs stdout/stderr.	Sesión SSM; docker ps/logs/stats.
Nginx	Ingreso, proxy y errores del servidor web.	docker logs datalegal-web.
FastAPI	Excepciones, respuestas y arranque/migraciones.	docker logs datalegal-backend.
PostgreSQL	Arranque, conexiones y errores de motor.	docker logs datalegal-db y pg_isready.
Auditoría DataLegal	Acciones autenticadas por tenant y usuario.	Módulo Audit log; permisos de lectura.

6.2 Comandos de observación

```
# Ventana corta, sin seguir indefinidamente
docker logs --since 15m --timestamps datalegal-backend
docker logs --since 15m --timestamps datalegal-web
docker logs --since 15m --timestamps datalegal-db

# Filtrar señales frecuentes sin imprimir variables de entorno
docker logs --since 60m datalegal-backend 2>&1 | \
  rg -i 'error|exception|traceback|timeout|429|500|502|503|504'
```

Protección de evidencia: No adjuntar volcados completos si contienen correos, IDs o payloads. Recortar al intervalo relevante, enmascarar datos personales y conservar el original en un repositorio de evidencia con acceso controlado.

6.3 Alertas mínimas recomendadas

Alerta	Condición inicial	Acción
Ingreso caído	GET /health falla 2 veces en 5 min	Abrir SEV-1 y verificar CloudFront/origen.
Errores de servidor	5xx >2 % durante 5 min	SEV-2; correlacionar backend y DB.
Status check EC2	Falla de instancia o sistema	SEV-1; consola AWS y recuperación.
Disco	Uso ≥80 %	SEV-2 preventivo; identificar crecimiento.
Reinicios	RestartCount aumenta sin cambio	SEV-2; capturar causa antes de reiniciar.
Respaldo	Antigüedad >24 h o checksum ausente	SEV-2 de continuidad.
Seguridad	Picos 401/423/429 o patrón anómalo	Escalar a Seguridad y preservar logs.

Las alarmas no están creadas por `deploy-datalegal.sh`; requieren configuración operativa adicional.

6.4 Job de alertas internas

El repositorio incluye `backend/scripts/scan_critical_alerts.py`. El script recorre tenants activos y crea alertas por plazos ARCO y auditorías; es idempotente y apto para ejecución programada. El despliegue AWS actual no instala el cron automáticamente.

```
# Ejecución manual controlada dentro del backend  
docker exec datalegal-backend python scripts/scan_critical_alerts.py
```

- Programar solo después de definir propietario, frecuencia, log y alerta de fallo.
- Validar primero en no producción y confirmar que no duplica alertas.
- Registrar el resultado y la cantidad de tenants revisados.

7. Administración de usuarios y acceso

DataLegal implementa RBAC por tenant. Los roles de sistema son SUPER_ADMIN, DPO, ADMIN, DEPT_HEAD y AUDITOR, además de roles personalizados. La interfaz de Usuarios permite crear y eliminar; el backend también permite actualizar rol, estado, departamento y contraseña.

Mínimo privilegio: Asignar el rol más restrictivo que permita la función. Las cuentas administrativas deben ser nominativas, con MFA habilitado y sin uso compartido.

7.1 Alta de usuario

- Confirmar ticket aprobado, tenant, nombre, correo, rol, departamento y fecha de vigencia.
- Ingresar a Usuarios con una cuenta autorizada (SUPER_ADMIN, DPO o ADMIN del tenant).
- Seleccionar Crear usuario y completar nombre, correo, contraseña temporal y rol.
- Usar una contraseña temporal generada por el gestor aprobado; no copiarla al ticket.
- Guardar y comprobar que el usuario aparece activo en el tenant correcto.
- Entregar usuario y secreto por canales separados; solicitar configuración de MFA.
- Registrar evidencia sin mostrar el secreto y cerrar la solicitud con el aprobador.

7.2 Política de contraseña verificada

- Mínimo 8 caracteres.
- Al menos una mayúscula, una minúscula, un número y un carácter especial.
- La contraseña se almacena como hash bcrypt; nunca debe consultarse ni recuperarse en texto claro.
- No existe flujo de autoservicio de recuperación en el código revisado; el cambio administrativo requiere autorización.

7.3 Cambio de rol o estado

- Validar solicitud y evitar incompatibilidades de funciones.
- Identificar el usuario por ID dentro del tenant correcto.
- Aplicar el cambio mediante un cliente administrativo autorizado o el endpoint PUT `/api/v1/users/<USER_ID>`.
- Confirmar que el rol exista; los roles personalizados se validan contra la base del tenant.
- Pedir al usuario cerrar sesión y volver a entrar para obtener un token con las nuevas atribuciones.
- Revisar el Audit log y adjuntar evidencia al ticket.

```
# Ejemplo conceptual; resolver token e ID desde el gestor/ticket autorizado
curl --request PUT 'https://<CLOUDFRONT_DOMAIN>/api/v1/users/<USER_ID>' \
--header 'Authorization: Bearer <ADMIN_TOKEN>' \
--header 'Content-Type: application/json' \
--data '{"is_active": false}'
```

Preferencia de baja: Desactivar antes que eliminar cuando se necesite conservar continuidad de auditoría. La interfaz actual expone eliminación; si se usa, verificar dependencias y aprobación porque la acción es irreversible desde la aplicación.

7.4 Bloqueo y desbloqueo

Después de cinco contraseñas incorrectas, la cuenta se bloquea durante 15 minutos. Un login correcto elimina intentos fallidos y bloqueo. Además, login y MFA tienen límite de 20 solicitudes por minuto; una sesión expira tras 30 minutos de inactividad.

Síntoma	Causa probable	Respuesta
423 Account locked	Cinco intentos fallidos	Esperar 15 min; validar identidad; no seguir intentando.
401 Invalid credentials	Correo/secreto incorrecto	Confirmar usuario y proceso de cambio autorizado.
401 inactivity	30 min sin actividad	Autenticar nuevamente; es comportamiento esperado.
429 Too Many Requests	Límite por IP	Detener automatismo/reintentos y esperar ventana.
MFA requerido	Cuenta con TOTP	Completar código; no deshabilitar como atajo.
Cuenta inactiva	is_active=false	Solo reactivar con solicitud aprobada.

7.5 Desbloqueo excepcional por base

Último recurso: No hay endpoint específico de desbloqueo. Preferir la espera automática. Solo L2 autorizado puede limpiar locked_until y failed_attempts, con identidad verificada, respaldo y ticket; nunca modificar la contraseña hash manualmente.

```
# Sesión SSM; consulta previa y cambio acotado a un correo aprobado
docker exec -it datalegal-db psql -U datalegal -d datalegal
SELECT id, email, is_active, failed_attempts, locked_until
FROM users WHERE email = '<USER_EMAIL>';
BEGIN;
UPDATE users SET failed_attempts = 0, locked_until = NULL
WHERE email = '<USER_EMAIL>';
COMMIT;
```

- Ticket y aprobador registrados.
- Identidad del solicitante verificada por canal corporativo.
- Consulta previa muestra exactamente una cuenta del tenant esperado.
- Cambio limitado a failed_attempts y locked_until.
- Login validado sin registrar la contraseña.
- Auditoría manual añadida al ticket porque el SQL no pasa por AuditLog de la aplicación.

8. Gestión de incidencias

Ciclo controlado de una incidencia

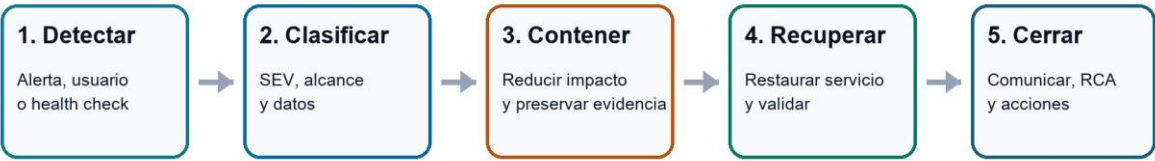


Figura 2. Flujo de respuesta a incidencias.

8.1 Registro mínimo

Campo	Contenido requerido
ID y hora UTC	<TICKET_ID>; detección, inicio de impacto y apertura.
Reportante	Canal y contacto; no copiar secretos.
Servicio/tenant	Componente afectado y alcance confirmado.
Síntoma	Qué falla, mensaje, frecuencia y pasos de reproducción.
Severidad	SEV-1 a SEV-4 con justificación.
Evidencia	Health, logs recortados, métricas y cambio reciente.
Responsable	Dueño actual, próximo paso y hora de actualización.
Resultado	Causa, corrección, validación, comunicación y acción preventiva.

8.2 Severidad y objetivos internos

Nivel	Criterio	Acuse	Actualización	Objetivo restaurar
SEV-1	Servicio caído, pérdida/corrupción o incidente de datos activo.	15 min	30 min	4 h
SEV-2	Función crítica degradada, respaldo vencido o impacto amplio.	30 min	60 min	8 h
SEV-3	Impacto limitado con alternativa; sin riesgo inmediato.	4 h hábiles	Diaria	3 días hábiles
SEV-4	Consulta, mejora o defecto cosmético.	1 día hábil	Según plan	Próxima versión

Objetivos propuestos para operación; no son SLA contractuales hasta su aprobación formal.

8.3 Triage de los primeros 15 minutos

- Confirmar el síntoma desde una segunda red o cuenta de prueba sin repetir acciones destructivas.
- Determinar alcance: una cuenta, un tenant, un módulo, API completa o ingreso público.
- Registrar hora UTC, status HTTP, request ID si existe y último cambio conocido.
- Ejecutar checks por capas: CloudFront, Nginx, backend, base y capacidad.
- Clasificar severidad y nombrar líder de incidente.
- Contener sin borrar evidencia; anunciar próxima actualización.

8.4 Comunicaciones

Momento	Mensaje mínimo
Apertura	Qué ocurre, alcance conocido, hora de inicio, severidad y próxima actualización.
Progreso	Qué se comprobó, mitigación activa, riesgo y siguiente hito.
Restauración	Servicio disponible, validaciones aprobadas y observación pendiente.
Cierre	Causa, duración, impacto, corrección y acciones con responsable/fecha.

Incidente de datos: Si existe posibilidad de acceso, exposición, pérdida o alteración de datos personales, informar inmediatamente al DPO/Seguridad. El equipo técnico preserva evidencia y contiene; el DPO decide evaluación y notificación regulatoria.

9. Guías de diagnóstico

9.1 La aplicación no carga / 502 / 504

- Probar /health y la raíz; registrar status, latencia y hora.
- Verificar CloudFront Enabled y errores de origen; no invalidar caché porque el despliegue la tiene desactivada.
- Abrir sesión SSM y confirmar EC2 Running con ambos status checks aprobados.
- Revisar datalegal-web y datalegal-backend con `docker ps` y `logs --since 15m`.
- Si Nginx está Up pero /health falla, probar el health interno del backend.
- Si backend no inicia, revisar Alembic, variables requeridas y conectividad PostgreSQL.
- Aplicar rollback si coincide con un despliegue; si no, contener y escalar L3.

9.2 Backend no inicia

Evidencia	Interpretación	Acción segura
RuntimeError de configuración	Falta SECRET_KEY, MFA_ENCRYPTION_KEY o CORS en producción.	Validar nombres/permisos del env; no imprimir valores.
Alembic multiple heads	Historial de migración divergente.	Detener; revisar heads y merge aprobado; no elegir al azar.
Connection refused DB	PostgreSQL no listo o red/contenedor ausente.	pg_isready, red datalegal y logs DB.
Port/name conflict	Contenedor previo conserva nombre o puerto.	Identificar contenedor; no eliminar sin rollback.
OOMKilled	Memoria insuficiente.	Preservar inspect/logs; reducir carga o escalar instancia.

9.3 Login y MFA

- 401 con usuario inexistente y contraseña errónea usa el mismo mensaje; no revelar existencia de cuentas.
- 423 se trata con espera o desbloqueo excepcional, nunca probando repetidamente.
- 429 indica rate limit por IP; revisar automatismos o ataques antes de elevar el límite.
- Un token mfa_pending no accede a rutas protegidas; completar verificación TOTP.
- Cambiar MFA_ENCRYPTION_KEY invalida la capacidad de descifrar secretos MFA existentes; planificar re-enrolamiento.

9.4 Base de datos o disco

- Detener cambios y confirmar si el problema es disponibilidad, capacidad, bloqueo o corrupción.
- Capturar `df -h`, `docker system df`, `pg_isready` y logs PostgreSQL del intervalo.
- No ejecutar `VACUUM FULL`, borrar volumen ni podar Docker durante un incidente sin aprobación.
- Si el volumen se aproxima a 85 %, abrir SEV-2 y liberar solo artefactos identificados como reemplazables.
- Si existe corrupción o pérdida, activar recuperación con un respaldo verificado; preservar el volumen afectado.

9.5 Frontend desactualizado

- La caché de CloudFront está configurada en TTL cero; primero comprobar qué commit y qué dist están en EC2.
- Comparar un marcador de versión aprobado o hash de artefacto; evitar asumir caché del navegador como única causa.
- Reconstruir con Node 20 y el commit aprobado; luego recrear datalegal-web y ejecutar aceptación.

10. Mantenimiento preventivo

Frecuencia	Actividad	Evidencia
Diaria	Health, contenedores, errores, disco, respaldo y tickets críticos.	Bitácora diaria.
Semanal	Tendencia CPU/memoria/disco, reinicios, usuarios privilegiados y jobs.	Informe semanal.
Mensual	Parches, imágenes base, dependencias, alarmas, costos y permisos IAM.	Cambio aprobado.
Trimestral	Restore de prueba, DR, revisión de runbooks, accesos y capacidad.	Acta de simulacro.
Por versión	Pruebas, backup, migraciones, despliegue, aceptación y rollback.	Registro de release.

10.1 Sistema operativo y Docker

- Revisar avisos de seguridad y necesidad real del parche.
- Crear ticket, ventana, respaldo y plan de reversión.
- Aplicar primero en un entorno de prueba equivalente.
- Actualizar paquetes o imágenes por versión explícita; no usar latest como evidencia de release.
- Reiniciar solo si es requerido y respetar el orden base-backend-web.
- Ejecutar aceptación y observar métricas durante al menos 15 minutos.

10.2 Limpieza segura

Antes de borrar: Clasificar cada objeto como activo, rollback, evidencia o reemplazable. docker system prune y la eliminación de volúmenes no forman parte de la rutina automática; un volumen Docker contiene la base productiva.

- Listado y tamaño de imágenes/contenedores registrados.
- Imagen de rollback preservada.
- Volumen datalegal_pgdata excluido explícitamente.
- Backups locales ya copiados y verificados fuera de la instancia.
- Resultado de espacio y health documentado después de la limpieza.

10.3 Dependencias y pruebas

- Backend: ejecutar pytest y revisar migraciones Alembic antes de publicar.
- Frontend: ejecutar tsc --noEmit y npm run build.
- Revisar vulnerabilidades de dependencias y cambios incompatibles de FastAPI, SQLAlchemy, React, Vite, Nginx y PostgreSQL.
- Conservar el commit, resultados de pruebas y notas de cambios; no basar una release solo en que el contenedor construye.

11. Despliegue controlado

Limitación verificada: deploy/aws/deploy-datalegal.sh aprovisiona o reutiliza la infraestructura. Si la instancia ya existe, el script puede iniciarla, pero no actualiza automáticamente el código ni recrea los contenedores. No usarlo como pipeline de releases sin ampliar y probar su comportamiento.

11.1 Puerta de entrada de release

- Commit inmutable aprobado y notas de versión disponibles.
- Pruebas backend y frontend aprobadas.
- Revisión de migraciones: un solo head, upgrade probado y compatibilidad evaluada.
- Respaldo PostgreSQL creado, checksum verificado y copia externa confirmada.
- Ventana, impacto, responsables y canal de comunicación definidos.
- Imagen/commit anterior y procedimiento de rollback identificados.
- Cuenta de prueba y criterios de aceptación preparados.

11.2 Procedimiento de actualización

- Abrir ticket de cambio y anunciar inicio de ventana.
- Conectar por SSM; registrar commit actual, imágenes, contenedores y health.
- Crear y verificar respaldo según el Manual de base de datos y respaldo.
- Obtener el commit aprobado con git fetch y dejar el repositorio en detached HEAD de ese commit.
- Construir una imagen backend etiquetada con el identificador de release.
- Construir el frontend con Node 20 usando el procedimiento reproducible aprobado.
- Validar migraciones contra PostgreSQL; detener si hay más de un head o error.
- Recrear backend y web durante la ventana, manteniendo la base y su volumen.
- Ejecutar aceptación completa, observar 15 minutos y anunciar cierre.

```
# Marcadores: no pegar secretos en la terminal compartida
cd /opt/datalegal/repo
git status --short
git rev-parse HEAD
git fetch --depth 1 origin <APPROVED_COMMIT>
git checkout --detach <APPROVED_COMMIT>
docker build -t datalegal-backend:<RELEASE_ID> ./backend
docker run --rm -v /opt/datalegal/repo/frontend:/app -w /app \
  node:20-alpine sh -c 'npm install --no-audit --no-fund && npm run build'
```

Migraciones: El Dockerfile ejecuta alembic upgrade head al arrancar. Una migración no compatible puede impedir un rollback solo de código; por eso el respaldo y la evaluación de reversibilidad son obligatorios antes de recrear el backend.

11.3 Validación de release

- Commit y etiqueta de imagen coinciden con el ticket.
- Los tres contenedores están Up y RestartCount estable.
- /, /health y /api/docs cumplen los resultados esperados.
- Login/MFA, dashboard y una lectura autenticada funcionan.
- No hay errores nuevos de migración, 5xx o conexión a base.
- El registro de cambio contiene inicio, fin, ejecutor, aprobador y evidencias.

12. Rollback

El rollback busca restablecer el servicio conocido sin destruir evidencia. Debe activarse cuando falla una validación crítica, aparece pérdida de datos, el error no puede mitigarse dentro de la ventana o el aprobador así lo decide.

12.1 Decisión

Condición	Respuesta
Falla solo frontend	Volver al commit/dist anterior y recrear web.
Falla backend sin cambio de esquema	Ejecutar imagen anterior y validar API.
Migración compatible hacia atrás	Volver código según plan aprobado; mantener esquema.
Migración incompatible o corrupción	Detener escrituras y restaurar respaldo en entorno limpio.
Causa desconocida con impacto alto	SEV-1; preservar evidencia y elegir la última versión conocida.

12.2 Procedimiento

- Declarar rollback, congelar cambios y registrar hora/razón.
- Capturar logs, commit, imágenes, estado de migración y métricas antes de sustituir componentes.
- Seleccionar la versión anterior documentada; no usar una etiqueta mutable.
- Si el esquema es compatible, recrear backend/web con artefactos anteriores.
- Si requiere datos anteriores, restaurar en un entorno limpio y validar antes de promover.
- Ejecutar aceptación completa, comparar datos críticos y observar estabilidad.
- Comunicar restauración y abrir análisis de causa raíz.

No hacer: No ejecutar alembic downgrade ni sobrescribir el volumen productivo solo para ahorrar tiempo. La reversión de esquema debe estar diseñada, probada y aprobada para esa migración específica.

12.3 Cierre del rollback

- Versión conocida restaurada y documentada.
- Health, login, lectura y auditoría aprobados.
- Integridad de datos comprobada por propietario funcional.
- Incidente y cambio vinculados.
- Release defectuosa bloqueada para evitar redespliegue accidental.
- RCA y acciones preventivas con fecha y responsable.

13. Seguridad y continuidad

13.1 Controles de operación segura

Control	Aplicación
Acceso	SSM e IAM con mínimo privilegio; cuentas nominativas y MFA.
Secretos	Fuera de Git y tickets; archivo productivo root-only; rotación controlada.
Red	Origen EC2 solo desde CloudFront; API y DB sin exposición pública.
Sesión	JWT 30 min; inactividad 30 min; MFA TOTP; bloqueo 5 intentos/15 min.
Auditoría	Revisar Audit log y complementar cambios directos con ticket firmado.
Datos	Cifrado EBS, backups cifrados y copia fuera de la instancia.
Evidencia	UTC, integridad, acceso restringido, retención y cadena de custodia.

Hallazgo del repositorio: La documentación AWS advierte de una credencial histórica en un archivo de entorno rastreado. Debe tratarse como comprometida: rotar en el proveedor, retirar el valor del historial y conservar únicamente una plantilla sin secretos.

13.2 Objetivos de continuidad

Objetivo	Meta	Cómo demostrarlo
RPO	≤24 horas	Último backup exitoso y checksum dentro de ventana.
RTO	≤4 horas	Simulacro medido desde declaración hasta aceptación.
Retención	30 copias diarias como base	Inventario y política aprobada; copia externa.
Prueba	Trimestral	Restore aislado, validación y acta.

RPO/RTO y retención base: `backend/scripts/backup.py` y módulo `frontend Backups`.

13.3 Activación de recuperación

- Declarar SEV-1, asignar líder y detener escrituras si hay riesgo de corrupción.
- Preservar instancia/volumen afectados; no reutilizarlos como destino de restore.
- Seleccionar el último backup verificado anterior al incidente y confirmar checksum.
- Preparar infraestructura limpia y el mismo commit de aplicación compatible.
- Restaurar PostgreSQL, ejecutar validaciones técnicas y luego validación funcional.
- Cambiar el tráfico solo con aprobación; monitorizar y mantener plan de retorno.
- Cerrar con tiempos reales, pérdida de datos calculada y acciones correctivas.

Backups en producción: En PostgreSQL, el botón Crear backup de la aplicación genera un registro PENDING; no ejecuta pg_dump. La copia real y la verificación externa deben ser operadas según el manual de base de datos/respaldo.

14. Escalamiento y soporte

14.1 Árbol de decisión

- ¿Hay indisponibilidad total, datos en riesgo o posible brecha? Declarar SEV-1 y convocar L2, L3 y DPO/Seguridad.
- ¿Falla una función crítica o el respaldo está fuera de RPO? Declarar SEV-2 y asignar L2/L3.
- ¿Es una cuenta o flujo con alternativa? L1 documenta, resuelve runbook o escala como SEV-3.
- ¿Es consulta/mejora sin impacto? Registrar SEV-4 y priorizar en backlog.

14.2 Cuándo escalar

A	Escalar cuando
L2 Operaciones	Health falla, contenedor reinicia, disco/DB/CloudFront o se requiere SSM.
L3 Desarrollo	Excepción reproducible, migración, defecto de código o incompatibilidad de versión.
DPO/Seguridad	Posible acceso indebido, exposición, pérdida, alteración o exfiltración de datos.
AWS / proveedor	Falla de servicio regional, status check de sistema o recurso no recuperable internamente.
Propietario funcional	Integridad/resultado de negocio dudoso, impacto regulatorio o autorización de restore.

14.3 Directorio controlado

Función	Contacto	Horario / alterno
Mesa de ayuda	<CANAL_L1>	<HORARIO_L1> · <ALTERNO>
Operaciones	<CONTACTO_L2>	<GUARDIA_L2>
Desarrollo	<CONTACTO_L3>	<GUARDIA_L3>
DPO / Seguridad	<CONTACTO_SEGURIDAD>	<GUARDIA_SEGURIDAD>
Aprobador negocio	<CONTACTO_NEGOCIO>	<ALTERNO_NEGOCIO>
AWS / proveedor	<ID_CUENTA_SOPORTE>	<PLAN_SOPORTE>

Mantenimiento del directorio: Completar en un repositorio restringido y revisar mensualmente. No publicar teléfonos personales, credenciales ni IDs sensibles en la copia académica del manual.

15. Checklists operativos

15.1 Diario

- URL pública y HTTPS disponibles.
- /health = 200, status=ok y environment=production.
- /api/docs = 404.
- datalegal-web, datalegal-backend y datalegal-db están Up.
- Sin reinicios inesperados ni errores 5xx recurrentes.
- Disco <70 % o tendencia explicada.
- Último backup real dentro de 24 h con checksum.
- Alertas/tickets críticos con responsable y próxima actualización.
- Bitácora firmada por operador.

15.2 Semanal

- Tendencias de CPU, memoria, disco, 4xx/5xx y latencia revisadas.
- RestartCount y logs de los tres contenedores revisados.
- Backups de siete días inventariados; fallos explicados.
- Usuarios privilegiados, altas/bajas y accesos excepcionales reconciliados.
- Jobs de alertas internas y sus logs revisados.
- Cambios e incidentes abiertos con fecha objetivo.
- Capacidad y costos AWS sin desviaciones anómalas.

15.3 Mensual

- Parches de sistema e imágenes base evaluados.
- Dependencias backend/frontend y vulnerabilidades revisadas.
- IAM, SSM, grupo de seguridad y CloudFront revisados.
- Rotación de secretos según política; sin valores en Git/tickets.
- Alarmas y destinatarios de escalamiento probados.
- Retención de logs/backups y copia externa verificadas.
- Manual actualizado si cambió arquitectura, comandos o responsables.

15.4 Trimestral

- Restore de PostgreSQL en entorno aislado completado dentro del RTO.
- Simulacro de indisponibilidad y comunicación ejecutado.
- RPO real calculado y pérdida máxima aceptable ratificada.
- Accesos privilegiados recertificados.
- Riesgo de instancia única y plan de alta disponibilidad revisados.
- Acciones de incidentes anteriores comprobadas, no solo cerradas.

16. Plantillas de registro

16.1 Bitácora diaria

Fecha/hora UTC	Operador	Control	Resultado	Ticket / evidencia
<UTC>	<NOMBRE>	Health público	<OK/NO OK>	<REFERENCIA>
<UTC>	<NOMBRE>	Contenedores/capacidad	<OK/NO OK>	<REFERENCIA>
<UTC>	<NOMBRE>	Respaldo/RPO	<OK/NO OK>	<REFERENCIA>

16.2 Registro de cambio

Campo	Valor
Cambio / ticket	<CHANGE_ID>
Commit / release	<COMMIT_INMUTABLE> / <RELEASE_ID>
Riesgo e impacto	<DESCRIPCIÓN>
Backup	<ARCHIVO> · <SHA256> · <UBICACIÓN_CONTROLADA>
Ventana	<INICIO_UTC> a <FIN_UTC>
Ejecutor / aprobador	<NOMBRE> / <NOMBRE>
Validación	<CHECKS Y RESULTADOS>
Rollback	<VERSIÓN / DECISIÓN / RESULTADO>

16.3 Registro de incidencia

Campo	Valor
Incidente / severidad	<INCIDENT_ID> / <SEV>
Inicio / detección	<UTC> / <UTC>
Alcance	<USUARIOS_TENANTS_COMPONENTES>
Evidencia inicial	<HEALTH_LOGS_MÉTRICAS_CAMBIO>
Contención	<ACCIÓN_Y_HORA>
Restauración	<ACCIÓN_VALIDACIÓN_HORA>
Causa raíz	<CAUSA_TÉCNICA_Y_SISTÉMICA>
Acciones	<RESPONSABLE_FECHA_CRITERIO>

17. Referencia técnica y limitaciones

Tema	Archivo fuente
Arquitectura AWS	docs/deployment-aws.md; deploy/aws/deploy-datalegal.sh
Contenedores	backend/Dockerfile; docker-compose.yml
Health y docs	backend/app/main.py
Seguridad/configuración	backend/app/core/config.py; security.py; rate_limit.py
Usuarios y bloqueo	backend/app/api/v1/users.py; auth.py; models/user.py
Permisos	backend/app/core/permissions.py
Backups	backend/app/api/v1/backups.py; backend/scripts/backup.py
Alertas internas	backend/scripts/scan_critical_alerts.py
Interfaz operativa	frontend/src/pages/UserManagement.tsx; Backups.tsx

17.1 Limitaciones conocidas

- Instancia única sin balanceador ni réplica de base.
- El script AWS no configura alarmas, cron de alertas, backup PostgreSQL externo ni restore automático.
- El módulo Backups no ejecuta pg_dump en PostgreSQL; registra PENDING.
- No existe endpoint dedicado de desbloqueo ni recuperación de contraseña de autoservicio.
- Los procedimientos con objetivos internos requieren aprobación y ensayo antes de considerarse SLA.

Criterio de actualización: Regenerar y reaprobar este manual cuando cambien la arquitectura, nombres de contenedor, rutas de health, política de acceso, migraciones, backup, responsables o metas de continuidad.